

TEKNİK DELİL RAPORU

Sapphire B2B Platformuna Yönelik Süregelen Siber Saldırı

Rapor No	SAP-CYBER-2026-0428
Saldırı Tarihi	28 Nisan 2026 12:17 UTC — 29 Nisan 2026 10:27 UTC (devam ediyor)
Toplam Süre	22 saat+ (iki gün boyunca)
Hedef	sapphiresc.com — Sapphire B2B Platform
İlişkilendirilen IP #1	84.44.79.182 — Bursa, TR (Vodafone, sabit hat, AIT ofis)
İlişkilendirilen IP #2	131.222.238.224 — İstanbul, TR (4GNET, mobil internet)
İlişkilendirilen IP #3	172.86.70.20 / 2a0b:f4c2::6 — Tor exit node
Parmak İzi	curl/8.12.1 (tüm IP'lerde aynı)
Altyapı Bağlantısı	84.44.79.182 üzerinde aitools.ait.com.tr servis ediliyor
Sahte Hesap Sayısı	42+
Toplam Saldırı Olayı	SSRF 73+, admin denemesi 25+, RCE teşebbüsü 3+
Ek Dosyalar	evidence/ klasörü — 70+ delil dosyası, SHA-256 hashli

1. OLAY ÖZETİ

28-29 Nisan 2026 tarihlerinde sapphiresc.com platformuna hedefli, sistematik ve süregelen bir siber saldırı gerçekleştirilmektedir. Saldırgan sahte hesaplar açarak platforma giriş yapmış, ardından SSRF, port tarama, credit manipölasyonu, XSS, phishing ve Redis üzerinden uzaktan komut çalıştırma (RCE) denemeleri gerçekleştirmiştir. Saldırı iki gün boyunca, 3 farklı IP adresinden (ofis hattı, mobil internet, Tor) devam etmiştir.

Saldırıyla ilişkilendirilen ana IP adresi (84.44.79.182) üzerinde, A.I.T. Bilgisayar Sistemleri'ne ait aitools.ait.com.tr içeriğinin servis edildiği tespit edilmiştir. A.I.T., saldırıya uğrayan platformun doğrudan rakibidir (MiraB2B ürünü).

2. KRONOLOJİK OLAY AKIŞI

Tüm olaylar UTC saatiyle (Türkiye = UTC + 3 saat) listelenmiştir.

GÜN 1 — 28 Nisan 2026

Saat (UTC)	Olay	Delil Kaynağı
12:17:10	Sahte hesap oluşturuldu: 'PenTest User' / pentester1777378590@deltajohnsons.com	PostgreSQL User tablosu (D005)
12:18:46	Credit manipülasyonu başladı: İlk deneme -1000, ardından +100 enjeksiyonu	PostgreSQL Credit tablosu (D007)
12:19:46	+5.000 credit enjeksiyonu	Credit tablosu (D007)
12:32:43	Admin paneline yetkisiz erişim denemeleri: /api/admin/stats, recent-users, recent-orders, fix-payment	Railway log (D002)
12:34:11	+10.000 credit enjeksiyonu	Credit tablosu (D007)
12:45:55	Path traversal denemesi: Dosya adı: ../../etc/passwd.png	Railway log (D003)
13:01:13	SSRF başlangıcı — AWS IMDS metadata erişim teşebbüsü: 169.254.169.254/latest/meta-data/hostname	Railway log (D003)
13:09:58	ECS container credential çalma denemesi: 169.254.170.2/v2/credentials/	Railway log (D003)
13:13:59	AIT sunucusunda (84.44.79.182) uygulama build edildi (Vite timestamp — destekleyici zaman korelasyonu)	HTML snapshot (D019)
13:20:13	Webhook.site token oluşturuldu — 84.44.79.182 IP'sinden Token: e9da1ee6-ded1-4e10-8dc5-0d5ad73352a3 Araç: curl/8.12.1	Webhook.site API (D009) Üçüncü parti kayıt
13:20:27	İlk SSRF callback: Sapphire sunucusu (162.220.234.129) webhook.site'a istek yaptı — SSRF teyidi	Webhook.site (D010) Üçüncü parti kayıt
13:32:58	84.44.79.182'den Firefox 150.0 ile webhook.site kontrol edildi (sonuçları izleme)	Webhook.site (D010)
13:40:36	Otomatik port tarama: 1 saniyede 8+ port 5432, 6379, 27017, 9200, 8443, 9090, 3001, 4000...	Railway log (D003)
13:46:34	84.44.79.182'den Firefox ile tekrar kontrol	Webhook.site (D010)
15:09:23	'SSRF Proof' SVG dosyası sisteme yüklendi İçerik: keşfedilen iç servislerin listesi	CDN + DB (D024, D006)
15:10:16	'SSRF Data Exfil Proof' SVG yüklendi İçerik: tam kullanıcı veri dökümü (JSON)	CDN + DB (D025, D006)
15:13:50	API key oluşturuldu: 'pentest-key' (vectorize scope)	DB ApiKey (D008)
15:15:25	API key oluşturuldu: 'admin-key' (admin scope!) Kalıcı erişim (persistence) girişi	DB ApiKey (D008)
20:04:40	İkinci 'PenTest User' hesabı açıldı Saldırı mesai dışı da devam ediyor	PostgreSQL User
20:39:48	İkinci webhook.site token oluşturuldu Bu sefer farklı IP: 131.222.238.224 (İstanbul, 4GNET mobil) Araç: yine curl/8.12.1	Webhook.site API (D-NEW-webhook2)

Saat (UTC)	Olay	Delil Kaynağı
20:56—21:30	XInclude ile dosya okuma denemeleri: file:///etc/hostname file:///app/src/app/api/export/route.ts (kaynak kod çalma teşebbüsü)	CDN SVG (D-NEW-PenTest)
23:48:45	httpbin.org üzerinden base64-encoded SVG payload XInclude file:///etc/hostname içeriyor	DB Pattern tablosu

GÜN 2 — 29 Nisan 2026

Saat (UTC)	Olay	Delil Kaynağı
00:08—00:39	Toplu hesap oluşturma: 'NewPenTest2', 8x 'PT', 9x 'check' exfil_100000—100008 (otomatik script — 1 sn aralıklarla)	PostgreSQL User
08:06—08:52	Yeni hesaplar: 'Test User', 'Test User3', 'Test User4', 'Test5', 'Farm', 'ssrf-test'	PostgreSQL User
08:13:51	SSRF devam: 127.0.0.1:3000 port tarama	Railway log (D-NEW-attack-logs)
08:24—08:42	Admin paneline 6x yetkisiz erişim denemesi	Railway log
08:31:10	Senin domain'inle sahte hesaplar: admin@sapphiresc.com, info@sapphiresc.com, support@sapphiresc.com, test@sapphiresc.com	PostgreSQL User
08:33:37	'Internal Data Exfil' SVG yüklendi SSRF ile elde edilen verilerin kaydı	CDN SVG (D-NEW-TestUser4)
08:34:14	'passwd ref' SVG — file:///etc/passwd okuma denemesi	CDN SVG (D-NEW-TestUser4)
08:44:41	Stored XSS denemesi: <script>alert('XSS on ' + document.domain)</script>	CDN SVG (D-NEW-Test5)
08:46:09	Docker daemon port tarama (YENİ vektör): 127.0.0.1:2375, :2376, :4243	Railway log
08:52:46	Phishing SVG yüklendi: Sahte login formu → evil.example.com/steal	CDN SVG (D-NEW-ssrf-test)
09:52—09:57	Cloudflare Security Analytics'te 84.44.79.182 görünüyor: /api/export, /api/vectorize, /dashboard (AIT ofis IP'si bugün de aktif)	Cloudflare Analytics (ekran görüntüsü)
10:03—10:20	4 yeni hesap: 'combo', 'txt', 'err', 'dl' Export işlemleri devam ediyor	PostgreSQL User + Credit
10:22:36	Tor'a geçiş — 172.86.70.20 (T1 country code) Araç: hala curl/8.12.1 Forensic logger ilk yakalamayı yaptı	SecurityLog DB tablosu
10:22—10:27	Redis Gopher SSRF → RCE teşebbüsü: 1) gopher://127.0.0.1:6379 → Redis GET komutu 2) Redis Lua io.popen() → shell komutu çalıştırma (find /app, find /tmp, ls *.tiff *.pdf) 3) Redis Lua → /etc/passwd okuma	SecurityLog DB + paste.rs payload'ları (D-LIVE)

3. İLİŞKİLENDİRİLEN IP ADRESLERİ VE ALTYAPI BAĞLANTISI

3.1 Tespit Edilen IP Adresleri

IP Adresi	Konum	ISP / Tür	Tespit Yöntemi	curl/8.12.
84.44.79.182	Bursa, TR	Vodafone (sabit hat) proxy=false	Webhook.site token API + Cloudflare Analytics	Evet
131.222.238.224	İstanbul, TR	4GNET (mobil internet) mobile=true	Webhook.site token #2	Evet
172.86.70.20	Tor exit (DE)	Tor anonim ağ country=T1	Forensic SecurityLog DB	Evet
2a0b:f4c2::6	Tor exit (IPv6)	Tor anonim ağ country=T1	Forensic SecurityLog DB	Evet

4 farklı IP adresinde de aynı araç (curl/8.12.1), aynı e-posta domain'i (deltajohnsons.com) ve aynı saldırı paterni kullanılmıştır. Bu, tüm aktivitenin aynı kişi veya ekip tarafından gerçekleştirildiğine kuvvetle işaret etmektedir.

3.2 Ana IP'nin (84.44.79.182) A.I.T. Altyapısıyla İlişkisi

Bu IP'de çalışan web servisleri incelenmiştir:

Bulgu	Değer	Nasıl Doğrulandır
Port 5000 — HTML meta tag	og:url = "https://aitools.ait.com.tr" og:site_name = "AIT AI-Tools" title = "AI Pattern Generator"	curl http://84.44.79.182:5000/ (snapshot: D019)
Port 5001 — Login sayfası	AIT logolu 'Archivist' admin paneli	curl http://84.44.79.182:5001/panel (snapshot: D020, D021)
aitools.ait.com.tr domain	ait.com.tr'nin alt alan adı	dig aitools.ait.com.tr
ait.com.tr WHOIS	Kayıt sahibi: A.I.T. BİLGİSAYAR SİSTEMLERİ MAKİNE SAN. VE TİC. LTD. ŞTİ.	whois ait.com.tr (kayıt: D012)
Shodan.io taraması	Port 80, 5000 açık (27 Nisan 2026)	shodan.io/host/84.44.79.182 (kayıt: D023)
Cloudflare Investigate	AS15924 Vodafone Net, TR	Cloudflare dashboard

3.3 Tor Arkasındaki Gerçek IP Tespiti

Saldırgan 29 Nisan 10:22 UTC'de Tor'a geçmiştir. Ancak aynı gün 09:52-09:57 UTC'de (Tor'a geçmeden 25 dakika önce) Cloudflare Security Analytics'te 84.44.79.182 IP'sinden sapphiresc.com'a erişim kaydedilmiştir. Her iki oturumda da:

- Aynı araç: curl/8.12.1
- Aynı e-posta domain'i: deltajohnsons.com
- Aynı saldırı vektörleri: SSRF, export API istismarı
- 25 dakikalık geçiş süresi: normal IP'den Tor'a

Kesin abone tespiti, BTK aracılığıyla 84.44.79.182 IP'sinin 28-29 Nisan tarihli Vodafone abone bilgilerinin istenmesiyle yapılmalıdır.

4. SALDIRI VEKTÖRLERİ

Vektör	Açıklama	Sonuç	Delil
SSRF (73+ olay)	Export API'ye internal URL gönderilerek sunucunun iç ağa istek yapması sağlandı. 18 farklı port tarandı.	Portlar kapalıydı (ECONNREFUSED). SSRF çalıştığı webhook callback ile teyit edildi.	D003, D010
AWS IMDS (9 endpoint)	169.254.169.254 metadata servisi ve 169.254.170.2 ECS container credential erişim teşebbüsü	404 — Railway IMDS expose etmiyor	D003
Redis RCE (3 payload)	gopher:// protokolü ile Redis'e Lua script gönderme → io.popen() ile shell komutu çalıştırma denemesi: find /app, ls /tmp/*.tiff, /etc/passwd	Başarısız — Redis erişilemedi	D-LIVE-payload paste.rs kayıtları
Credit Manipülasyonu	Kayıttan 90 saniye sonra credit API istismar edildi: +100, +5.000, +10.000 enjeksiyonu (toplam 15.100)	Başarılı — sınırsız kullanım sağlandı	D007
Path Traversal	../../../../etc/passwd.png dosya adı ile sunucu dosya sistemine erişim denemesi	Engellenemedi (güvenlik yaması uygulandı)	D003
Stored XSS	SVG dosyasına <script> tag'i yerleştirme alert('XSS on ' + document.domain)	CDN'de depolandı (silinmeli)	D-NEW-Test5 SVG
Phishing	SVG içine sahte login formu yerleştirme → evil.example.com/steal'e POST	CDN'de depolandı (silinmeli)	D-NEW-ssrf-test SVG
Kaynak Kod Okuma	include ile file:///app/src/app/api/export/route.ts okuma denemesi	Başarısız	D-NEW-PenTest SVG
Docker Daemon	Port 2375/2376/4243 tarama (Docker socket erişimi)	ECONNREFUSED	D-NEW-attack-logs
Admin Brute-force	25+ yetkisiz admin endpoint denemesi (stats, recent-users, fix-payment)	401/403 — erişilemedi	D002, D004
Kalıcı Erişim	admin scope API key oluşturma 42+ sahte hesap açma	Key'ler devre dışı bırakıldı	D008

5. KEŞFEDİLEN TİCARİ BİLGİLER

Keşfedilen	Yöntem	Niteliği
AI desen üretim motorunun kapasitesi ve çıktı kalitesi	134 farklı desen üretimi	Ticari sır
Export pipeline (TIFF/PDF/PSD/Pack)	58+ export işlemi	Ticari sır
8K Upscale AI modelinin kapasitesi	6 adet 8K upscale	Ticari sır
İç ağ mimarisi (18 port haritası)	SSRF port tarama	Altyapı bilgisi
AI backend sağlayıcıları ve IP'leri (Railway, CoreWeave)	SSRF callback + SVG kaydı	Altyapı bilgisi
Credit/pricing modeli	Credit manipülasyonu	İş modeli

6. DELİL ENVANTERİ

Tüm delil dosyaları evidence/ klasöründe arşivlenmiştir. Her dosyanın SHA-256 hash değeri 08-hashes/SHA256SUMS.txt dosyasında kayıtlıdır. Doğrulama: sha256sum -c SHA256SUMS.txt

Klasör	İçerik	Dosya Sayısı
01-server-logs	Railway sunucu logları (28-29 Nisan)	5
02-database-dumps	User, Pattern, Credit (1500+), ApiKey, SecurityLog	12+
03-webhook-evidence	2 webhook.site token + 32 callback kaydı	4
04-whois-dns	WHOIS (5 domain), geolocation (3 IP), DNS kayıtları	11
05-attacker-server	84.44.79.182 HTML snapshot, AIT logosu, HTTP headers	5
06-cdn-artifacts	SSRF Proof SVG, XSS SVG, Phishing SVG, RCE payload, payload analizi, upscale görseller	12+
07-osint	GitHub profili, AIT/MiraB2B web sayfaları	5
Ek belgeler	Bilirkişi erişim rehberi, teknik değerlendirme notu, savcılık talep listesi, bağımsız doğrulama scripti, canlı saldırı raporu (29 Nisan)	7

7. KURULAN FORENSIC LOGLAMA SİSTEMİ

29 Nisan 2026 itibarıyla platforma forensic düzeyinde loglama sistemi kurulmuştur. Bu sistem, sonraki saldırı girişimlerinde delil niteliğinde kayıt tutmaktadır:

Kayıt Edilen	Kaynak	Depolama
Gerçek client IP (Cloudflare)	cf-connecting-ip header	SecurityLog DB + Railway log
Ülke ve şehir	cf-ipcountry, cf-ipcity	SecurityLog DB
Cloudflare Ray ID	cf-ray header	SecurityLog DB
User-Agent (tarayıcı/araç)	user-agent header	SecurityLog DB + Railway log
İşletim sistemi ve platform	sec-ch-ua-platform	SecurityLog DB
Request body (payload)	POST body (4KB'a kadar)	SecurityLog DB
İlişkili kullanıcı kimliği	Session'dan userId + email	SecurityLog DB
İstek path ve method	URL path + HTTP method	SecurityLog DB + Railway log

Bu kayıtlar 3 bağımsız yerde tutulmaktadır: Cloudflare (CDN düzeyinde), PostgreSQL SecurityLog tablosu (uygulama düzeyinde) ve Railway console log (platform düzeyinde). Saldıran bu kayıtların hiçbirini silemez veya değiştiremez.

8. ALINAN GÜVENLİK ÖNLEMLERİ

Önlem	Durum
42+ saldırgan hesap banlandı, credit sıfırlandı	Tamamlandı
3 API anahtarı devre dışı bırakıldı	Tamamlandı
SSRF koruması: URL allowlist (sadece CDN ve Replicate)	Deploy edildi
Internal IP/metadata/gopher/file protokolleri engellendi	Deploy edildi
Callback servisleri engellendi (webhook.site, paste.rs, httpbin vb.)	Deploy edildi
Path traversal koruması (../ ve dizin ayracı kontrolü)	Deploy edildi
API key scope kısıtlama (USER rolü admin scope alamaz)	Deploy edildi
Disposable e-posta domain'leri engellendi (deltajohnsons vb.)	Deploy edildi
Kendi domain'i ile kayıt engellendi (sapphiresc.com)	Deploy edildi
Bilinen saldırgan IP'leri engellendi (84.44.79.182, 131.222.238.224)	Deploy edildi
Tor exit node'ları engellendi (cf-ipcountry=T1)	Deploy edildi
Forensic loglama sistemi kuruldu (SecurityLog DB tablosu)	Deploy edildi
Deliller SHA-256 ile hashlenip arşivlendi	Tamamlandı
Wayback Machine arşivleri oluşturuldu	Tamamlandı

9. RESMİ ADLİ İNCELEME TALEPLERİ

Talep	Kurum	Amaç
84.44.79.182 IP abone bilgileri (28-29 Nisan 2026)	BTK → Vodafone Turkey	IP'nin kime tahsis edildiğinin resmi tespiti
131.222.238.224 IP abone bilgileri (28 Nisan 2026 gece)	BTK → 4GNET	İkinci IP'nin abone tespiti
Webhook.site token kayıtları (2 token)	Webhook.site (Danimarka) (uluslararası adli yardım)	Token oluşturan IP'nin ve callback'lerin resmi teyidi
sapphiresc.com erişim logları (28-29 Nisan)	Cloudflare Inc. (ABD)	Saldırgan IP'nin site erişim kayıtlarının teyidi
A.I.T. sunucu incelemesi (84.44.79.182)	A.I.T. Bilg. Sis. (Bursa) (arama kararı ile)	Hangi kullanıcıdan erişim yapıldığının tespiti
A.I.T. çalışan mesai kayıtları (28-29 Nisan)	A.I.T. Bilg. Sis.	Olay saatinde ofiste bulunan kişilerin tespiti
HTS kayıtları — telefon araması (28 Nisan, AIT → Sapphire)	BTK / Operatör	Hedef teyidi aramasının belgelenmesi

Webhook.site token #1 (e9da1ee6...) 5 Mayıs 2026'da, token #2 (aeae90e6...) 5 Mayıs 2026'da sona erecektir. Bu tarihlerden önce kayıtların resmi yollarla teyit edilmesi veya koruma altına alınması gerekmektedir.

10. SONUÇ

Mevcut bulgular, sapphiresc.com platformuna yönelik 28-29 Nisan 2026 tarihlerinde gerçekleştirilen saldırının tek seferlik bir merak veya otomatik bot taraması olmadığını göstermektedir. Olay, iki gün boyunca, 3 farklı IP adresinden, 42+ sahte hesapla, giderek yoğunlaşan saldırı vektörleriyle (SSRF → XSS → RCE) sürdürülmüş hedefli ve sistematik bir saldırdır.

Saldırıyla ilişkilendirilen ana IP adresi (84.44.79.182) üzerinde A.I.T. Bilgisayar Sistemleri ile ilişkili web içeriğinin servis edildiği tespit edilmiştir. A.I.T., saldırıya uğrayan platformun doğrudan rakibi olan MiraB2B ürününü işletmektedir. Bu bağlantı, olayın ticari motivasyonlu olabileceğine dair kuvvetli şüphe oluşturmaktadır. Kesin şahıs tespiti, Bölüm 9'daki resmi adli inceleme taleplerinin sonuçlarına bağlıdır.

Rapor Sonu

Oluşturma: 29/04/2026 13:41 UTC+3

Ek: evidence/ klasörü — 70+ delil dosyası, SHA-256 hashli